UNIVERSIDAD DE LA SABANA

Facultad de Ingeniería

Arquitectura Empresarial

Informe Consolidado del Semestre

Diagnóstico, Seguridad y Cumplimiento

Talleres 4, 5 y 6 — Proyecto Integrador

Equipo de trabajo: Cyber Nexus — Grupo 7

Caso de estudio:	Plataforma de gestión de propiedades y reservas
Cliente analizado:	Sistema integrado con API de Airbnb
Repositorio:	GitHub — Cyber Nexus Grp 7

18 de abril de 2026

Índice

1. Introducción General **3**
1.1. Contexto y Necesidad del Trabajo . . . 3
1.2. Estructura del Documento . . . 3

2. Parte I — Taller 4: Diagnóstico Técnico de Infraestructura **5**
2.1. Descripción General del Sistema . . . 5
2.2. Mapa de Infraestructura por Capas . . . 5
2.2.1. Capa de Frontend . . . 5
2.2.2. Capa de Seguridad . . . 5
2.2.3. Capa de API . . . 5
2.2.4. Capa de Cómputo . . . 5
2.2.5. Capa de Microservicios . . . 5
2.2.6. Cola de Eventos . . . 6
2.2.7. Capa de Datos . . . 6
2.2.8. Plataformas Externas . . . 6
2.3. Diagnóstico de Debilidades y Cuellos de Botella . . . 6
2.3.1. Cuellos de Botella Identificados . . . 6
2.3.2. Puntos Únicos de Falla (SPOF) . . . 6
2.3.3. Limitaciones de Escalabilidad . . . 7
2.3.4. Observabilidad y Monitoreo . . . 7
2.3.5. Seguridad . . . 7
2.4. Oportunidades de Mejora . . . 7
2.4.1. Alta Disponibilidad . . . 7
2.4.2. Escalabilidad . . . 7
2.4.3. Observabilidad . . . 8
2.4.4. Resiliencia en Integración Externa . . . 8
2.4.5. Seguridad Interna . . . 8
2.5. Conclusión del Taller 4 . . . 8

3. Parte II — Taller 5: Análisis de Amenazas con el Modelo STRIDE **9**
3.1. Introducción al Taller 5 . . . 9
3.2. Tabla STRIDE — Análisis de Amenazas por Componente . . . 10
3.3. Análisis de Resultados . . . 11
3.4. Buenas Prácticas de Ciberseguridad Aplicables . . . 11
3.5. Conclusión del Taller 5 . . . 11

4. Parte III — Taller 6: Evaluación de Cumplimiento Normativo **12**
4.1. Introducción al Taller 6 . . . 12
4.2. Marco Normativo Aplicable . . . 12
4.3. Descripción del Sistema Evaluado . . . 12
4.4. Checklist de Cumplimiento (Gobierno de Datos) . . . 13
4.5. Resultados del Análisis de Cumplimiento . . . 13
4.5.1. Cumplimientos Parciales . . . 13

4.5.2. Brechas Identificadas 14
4.6. Nivel de Madurez 14
4.7. Riesgos Asociados 14
4.8. Recomendaciones 14
4.8.1. Protección de Datos Personales 14
4.8.2. Seguridad de la Información 15
4.8.3. Gestión Operativa 15
4.8.4. Integraciones Externas 15
4.9. Conclusión del Taller 6 15

5. Parte IV — Integración de Hallazgos y Conclusiones Generales 16
5.1. Visión Integrada de los Tres Talleres 16
5.2. Plan de Acción Priorizado 16
5.3. Reflexión del Equipo sobre el Trabajo del Semestre 17
5.4. Conclusión General 17

6. Referencias Consolidadas 18
6.1. Arquitectura de Infraestructura (Taller 4) 18
6.2. Ciberseguridad (Taller 5) 18
6.3. Cumplimiento Normativo (Taller 6) 18

1. Introducción General

El presente documento consolida el trabajo realizado por el grupo **Cyber Nexus — Grupo 7** durante el semestre en la asignatura de **Arquitectura Empresarial**. A lo largo del curso se desarrollaron tres entregas sucesivas (Talleres 4, 5 y 6) que, en conjunto, constituyen un ejercicio integral de análisis arquitectónico, evaluación de seguridad y verificación de cumplimiento normativo sobre un mismo caso de estudio: una plataforma digital de gestión de propiedades y reservas que se integra con la API de Airbnb.

La decisión de unificar los tres informes en un único documento responde a una necesidad pedagógica y práctica: los tres talleres no son ejercicios aislados, sino capas complementarias de un mismo diagnóstico. El Taller 4 construye la base técnica al mapear la infraestructura; el Taller 5 añade la dimensión de ciberseguridad mediante el análisis STRIDE; y el Taller 6 cierra el ciclo con la verificación del cumplimiento normativo frente a la Ley 1581 de 2012 e ISO/IEC 27001. Solo cuando estas tres miradas se leen de forma conjunta se obtiene una visión completa del estado real del sistema y de las acciones que deben priorizarse.

Este informe está dirigido a dos audiencias principales. Por un lado, al **docente de la asignatura**, como evidencia consolidada del proceso, los hallazgos y las conclusiones alcanzadas durante el semestre. Por otro lado, a los **propios miembros del equipo**, como documento de referencia que recoge el conocimiento construido y que puede servir como base para futuros proyectos, certificaciones o intervenciones sobre sistemas con características similares.

1.1 Contexto y Necesidad del Trabajo

El caso de estudio seleccionado corresponde a un sistema real con múltiples frentes de análisis: infraestructura en la nube (AWS), arquitectura de microservicios, integraciones externas con plataformas de terceros, manejo de datos personales sensibles (clientes, reservas, pagos) y operación apoyada en herramientas manuales como hojas de cálculo. Esta combinación lo convierte en un escenario idóneo para aplicar los conceptos vistos en clase, ya que presenta los tres tipos de problemas que suelen encontrarse en la práctica profesional:

- **Problemas de diseño arquitectónico**: puntos únicos de falla, limitaciones de escalado, observabilidad parcial.
- **Problemas de ciberseguridad**: amenazas de spoofing, tampering, denegación de servicio e información expuesta.
- **Problemas de cumplimiento normativo**: ausencia de políticas de privacidad, falta de cifrado y de control de acceso basado en roles.

1.2 Estructura del Documento

El informe se organiza en tres partes principales, cada una correspondiente a uno de los talleres desarrollados, seguidas de una sección de integración de hallazgos y conclusiones generales:

1. **Parte I — Taller 4**: Diagnóstico técnico de la infraestructura.
2. **Parte II — Taller 5**: Análisis de amenazas con el modelo STRIDE.
3. **Parte III — Taller 6**: Evaluación de cumplimiento normativo y gobierno de datos.

4. **Parte IV**: Integración de hallazgos, conclusiones y referencias consolidadas.

2. Parte I — Taller 4: Diagnóstico Técnico de Infraestructura

2.1 Descripción General del Sistema

El sistema analizado es una **plataforma de gestión de propiedades y reservas** desplegada completamente en **AWS Cloud**. La arquitectura sigue un modelo orientado a microservicios con separación clara de capas: frontend, seguridad, API, cómputo, microservicios y datos. También integra plataformas externas como la **API de Airbnb** para sincronización de listados y reservas mediante webhooks.

Los usuarios principales del sistema son: inquilinos (*Tenants*), administradores de propiedades (*Property Managers*), personal de mantenimiento (*Maintenance Staff*) y huéspedes de reserva (*Booking Guests*).

2.2 Mapa de Infraestructura por Capas

2.2.1 Capa de Frontend

- **CDN** (*Content Delivery Network*): distribuye contenido estático con baja latencia a nivel geográfico.
- **Web App (React)**: interfaz de usuario servida desde el CDN.

2.2.2 Capa de Seguridad

- **WAF (Web Application Firewall)**: filtra tráfico malicioso antes de que llegue a los servicios internos.
- **Authentication**: gestiona la autenticación de usuarios (presumiblemente mediante JWT o OAuth).

2.2.3 Capa de API

- **Load Balancer**: distribuye las solicitudes entrantes entre los servidores de cómputo.
- **Public API & Webhooks**: punto de entrada para integraciones externas, incluyendo eventos de Airbnb.

2.2.4 Capa de Cómputo

- **API Server 1 y API Server 2**: dos instancias de servidor para procesamiento paralelo de solicitudes, lo que permite escalabilidad horizontal básica.

2.2.5 Capa de Microservicios

- **Integration Service**: gestiona la comunicación con plataformas externas.
- **Booking Service**: maneja la lógica de reservas.
- **Property Service**: administra los datos y operaciones relacionadas con propiedades.

2.2.6 Cola de Eventos

- **Message Queue**: desacopla la comunicación entre microservicios, permitiendo procesamiento asíncrono y resiliencia ante picos de carga.

2.2.7 Capa de Datos

- **Redis Cache**: caché en memoria para reducir la carga sobre la base de datos y mejorar tiempos de respuesta.
- **PostgreSQL Primary**: base de datos relacional principal.
- **PostgreSQL Replica**: réplica de lectura para alta disponibilidad y distribución de carga.
- **S3 Storage**: almacenamiento de objetos para backups y archivos estáticos.
- **Monitoring**: componente de observabilidad conectado a la capa de datos.

2.2.8 Plataformas Externas

- **Airbnb API**: sincroniza listados y reservas con el sistema mediante webhooks y eventos periódicos.

2.3 Diagnóstico de Debilidades y Cuellos de Botella

2.3.1 Cuellos de Botella Identificados

Tabla 1: Cuellos de botella identificados en la infraestructura

Componente	Problema Potencial	Nivel de Riesgo
Load Balancer	Punto único de falla si no tiene redundancia	**Alto**
WAF / Authentication	Si están en serie sin redundancia, una caída bloquea todo el acceso	**Alto**
PostgreSQL Primary	Toda la escritura pasa por un solo nodo; bajo carga alta puede ser cuello de botella	**Medio-Alto**
API Server 1 y 2	Solo 2 instancias; ante picos de tráfico puede ser insuficiente sin autoescalado	**Medio**
Message Queue	Si la cola no tiene redundancia, los mensajes pueden perderse	**Medio**

2.3.2 Puntos Únicos de Falla (SPOF)

- **Load Balancer**: no se evidencia un balanceador secundario ni configuración multi-AZ (múltiples zonas de disponibilidad) explícita en el mapa. Si falla, todo el tráfico queda bloqueado.
- **WAF**: un único WAF sin failover significa que un incidente en este componente puede hacer inaccesible todo el sistema.

- **PostgreSQL Primary**: aunque existe una réplica, la promoción automática de la réplica a primaria no siempre es instantánea, lo que puede generar ventanas de inactividad.

2.3.3 Limitaciones de Escalabilidad

El *Compute Layer* muestra únicamente dos servidores de API sin indicación de un mecanismo de autoescalado (como AWS Auto Scaling Groups). Ante campañas de alta demanda, estos dos nodos podrían saturarse. Los microservicios (Integration, Booking, Property) no muestran réplicas ni políticas de escalado independiente, lo que puede limitar el rendimiento de servicios muy demandados (por ejemplo, Booking Service durante temporada alta). Adicionalmente, la integración con Airbnb API depende de un único flujo de sincronización; si este falla, no se visualiza un mecanismo de reintento robusto o fallback.

2.3.4 Observabilidad y Monitoreo

El componente de *Monitoring* aparece únicamente conectado a la capa de datos. No se evidencia monitoreo explícito del Compute Layer, los microservicios ni la capa de API, lo que reduce la visibilidad ante fallos en esas capas. Se recomienda extender la observabilidad a todos los componentes críticos (Load Balancer, API Servers, microservicios) con métricas de CPU, latencia, tasa de errores y disponibilidad.

2.3.5 Seguridad

El WAF es el primer filtro de seguridad, lo cual es una buena práctica. Sin embargo, no se visualizan controles de seguridad internos entre microservicios (comunicación inter-servicio sin autenticación mutua podría ser un riesgo). Tampoco se aprecia cifrado explícito en tránsito entre capas internas, aunque podría estar implícito en la configuración de AWS.

2.4 Oportunidades de Mejora

2.4.1 Alta Disponibilidad

- Desplegar el Load Balancer y el WAF en **múltiples zonas de disponibilidad (Multi-AZ)** para eliminar puntos únicos de falla.
- Configurar **failover automático** entre PostgreSQL Primary y Replica mediante herramientas como AWS RDS Multi-AZ o Patroni.

2.4.2 Escalabilidad

- Implementar **AWS Auto Scaling Groups** en el Compute Layer para escalar automáticamente el número de API Servers según la carga.
- Evaluar el escalado independiente de cada microservicio mediante **AWS ECS** o **Kubernetes (EKS)**, de manera que el Booking Service pueda escalar de forma autónoma durante picos de reservas.

2.4.3 Observabilidad

- Extender el monitoreo a todas las capas utilizando herramientas como **CloudWatch**, **Prometheus** + **Grafana** o **Datadog**.
- Implementar **alertas proactivas** para detectar degradación de rendimiento antes de que impacte a los usuarios.

2.4.4 Resiliencia en Integración Externa

- Implementar un **mecanismo de reintentos con backoff exponencial** para los webhooks de Airbnb.
- Considerar un patrón **Circuit Breaker** para aislar fallos en la integración externa.

2.4.5 Seguridad Interna

- Adoptar un modelo de **Zero Trust** entre microservicios, con autenticación mutua (mTLS) o tokens de servicio internos.
- Realizar **auditorías de acceso** periódicas sobre la capa de datos y los microservicios.

2.5 Conclusión del Taller 4

La arquitectura analizada representa un diseño moderno y bien estructurado sobre AWS Cloud, con separación de responsabilidades por capas, uso de microservicios, caché, cola de mensajes y replicación de base de datos. Estas características son señales positivas de una infraestructura pensada para escalar.

Sin embargo, el diagnóstico revela oportunidades importantes en tres frentes: **eliminar puntos únicos de falla** (Load Balancer, WAF, base de datos primaria), **extender los mecanismos de escalado automático** (Compute Layer y microservicios), y **ampliar la cobertura de observabilidad** más allá de la capa de datos. Abordar estas mejoras permitiría al sistema soportar de manera confiable escenarios de alta demanda y garantizar la continuidad del negocio ante fallos inesperados.

3. Parte II — Taller 5: Análisis de Amenazas con el Modelo STRIDE

3.1 Introducción al Taller 5

El Taller 5 tuvo como objetivo aplicar el modelo **STRIDE** para identificar amenazas de ciberseguridad sobre los componentes críticos del sistema analizado en el Taller 4. El modelo STRIDE, desarrollado por Microsoft, clasifica las amenazas en seis categorías: *Spoofing* (suplantación de identidad), *Tampering* (manipulación), *Repudiation* (repudio), *Information Disclosure* (divulgación de información), *Denial of Service* (denegación de servicio) y *Elevation of Privilege* (elevación de privilegios).

Este análisis toma como insumo el mapa de infraestructura construido en el Taller 4 y lo enriquece con una perspectiva defensiva, identificando para cada componente crítico qué tipo de ataque podría sufrir, cuál sería su impacto y qué control mitigante se propone implementar.

3.2 Tabla STRIDE — Análisis de Amenazas por Componente

Tabla 2: Matriz STRIDE aplicada al sistema del cliente

Componente	Categoría STRIDE	Amenaza / Impacto / Control propuesto	Riesgo
Autenticación de usuarios	Spoofing	**Amenaza:** Un atacante roba credenciales y se hace pasar por un administrador. **Impacto:** Acceso no autorizado a reservas y datos de clientes. **Control:** Autenticación multifactor (MFA), contraseñas seguras y monitoreo de login.	**Alto**
API de reservas	Tampering	**Amenaza:** Manipulación de solicitudes de reserva enviadas al servidor. **Impacto:** Reservas incorrectas o pérdidas financieras. **Control:** Validación de solicitudes, tokens de autenticación y HTTPS.	**Alto**
Base de datos de reservas	Repudiation	**Amenaza:** Un usuario niega haber realizado una reserva o modificación. **Impacto:** Disputas y falta de trazabilidad. **Control:** Registro de auditoría (logs) con timestamps y seguimiento de usuarios.	**Medio**
Base de datos de clientes	Information Disclosure	**Amenaza:** Exposición de datos personales de clientes. **Impacto:** Violación de privacidad y problemas legales. **Control:** Cifrado de datos y control de acceso basado en roles.	**Alto**
Infraestructura de la plataforma	Denial of Service	**Amenaza:** Ataque de tráfico masivo que sobrecarga el sistema. **Impacto:** Caída del sistema e imposibilidad de hacer reservas. **Control:** Rate limiting, balanceadores de carga y protección DDoS.	**Alto**
Módulo de mantenimiento	Elevation of Privilege	**Amenaza:** Personal de mantenimiento obtiene permisos de administrador. **Impacto:** Control indebido del sistema. **Control:** Control de permisos por roles y revisión de accesos.	**Medio**
Integración con API externa	Tampering / Info. Disclosure	**Amenaza:** Manipulación de datos entre el sistema y plataformas externas. **Impacto:** Reservas duplicadas o filtración de datos. **Control:** Validación de webhooks, claves API seguras y cifrado.	**Medio**

3.3 Análisis de Resultados

Del análisis STRIDE se desprenden varias observaciones relevantes. En primer lugar, las amenazas de mayor impacto (clasificadas como *Alto*) se concentran en tres puntos: la **autenticación de usuarios**, la **API de reservas** y la **base de datos de clientes**. Estos tres componentes conforman el eje crítico del sistema, ya que son los que manejan directamente la identidad de los usuarios y los datos sensibles.

En segundo lugar, se identifica que la mayoría de los controles propuestos son técnicamente implementables con tecnologías estándar ampliamente disponibles (MFA, HTTPS, cifrado, logs, RBAC). Esto significa que el gap de seguridad no se debe a limitaciones tecnológicas sino a una falta de implementación formal de controles que ya son de uso común en la industria.

En tercer lugar, el análisis confirma un hallazgo del Taller 4: la exposición a **ataques de denegación de servicio (DoS)** sobre la infraestructura. Aunque el sistema cuenta con un WAF y un balanceador de carga, la ausencia de políticas explícitas de *rate limiting* y protección DDoS deja una ventana de vulnerabilidad que debe cerrarse.

3.4 Buenas Prácticas de Ciberseguridad Aplicables

A partir de la investigación complementaria se identificaron los siguientes marcos de referencia aplicables al sistema:

- **OWASP Top 10**: identifica las vulnerabilidades más críticas en aplicaciones web, incluyendo problemas de autenticación, exposición de datos sensibles y control de accesos.
- **Seguridad en la nube**: las arquitecturas cloud modernas implementan cifrado, monitoreo y control de accesos para proteger datos y servicios.
- **NIST Cybersecurity Framework**: propone cinco funciones principales para proteger sistemas: identificar, proteger, detectar, responder y recuperar frente a incidentes.
- **Seguridad en APIs (OWASP API Security)**: las APIs deben implementar autenticación fuerte, validación de solicitudes y limitación de tráfico para evitar accesos no autorizados o manipulación de datos.
- **Protección contra ataques DDoS**: utilización de balanceadores de carga y filtrado de tráfico para protegerse contra ataques de denegación de servicio.

3.5 Conclusión del Taller 5

El análisis STRIDE evidenció que el sistema presenta exposiciones relevantes en las seis categorías de amenaza, con tres de ellas clasificadas como de *alto riesgo*. La implementación de los controles propuestos (MFA, cifrado, logs, RBAC, protección DDoS, validación de webhooks) debería tratarse como una prioridad a corto plazo, especialmente porque se trata de controles estándar cuya ausencia constituye una desviación notable respecto a las buenas prácticas de la industria y a marcos como OWASP y NIST.

4. Parte III — Taller 6: Evaluación de Cumplimiento Normativo

4.1 Introducción al Taller 6

El presente componente tiene como objetivo evaluar el nivel de cumplimiento normativo del sistema de gestión de propiedades y reservas utilizado por el cliente. Este sistema administra información relacionada con clientes, reservas, inventario y operaciones, e incluye integraciones con plataformas externas como Airbnb. Dado que el sistema maneja datos personales, es necesario analizar su alineación con normativas nacionales e internacionales de protección de datos y seguridad de la información.

4.2 Marco Normativo Aplicable

El análisis se realizó teniendo en cuenta los siguientes marcos normativos:

- **Ley 1581 de 2012 (Colombia)**: regula la protección de datos personales y establece principios como legalidad, finalidad, libertad, veracidad, transparencia y seguridad.
- **Habeas Data**: garantiza el derecho de los usuarios a conocer, actualizar y rectificar su información personal.
- **ISO/IEC 27001**: estándar internacional para la gestión de la seguridad de la información, enfocado en la confidencialidad, integridad y disponibilidad.
- **Lineamientos MinTIC**: buenas prácticas promovidas por el Ministerio de Tecnologías de la Información y las Comunicaciones.

4.3 Descripción del Sistema Evaluado

El sistema analizado corresponde a una plataforma digital que permite gestionar propiedades en alquiler, administrar reservas y disponibilidad, manejar inventarios asociados a cada propiedad, registrar información de clientes e integrarse con plataformas externas como Airbnb para sincronización de reservas. Actualmente, gran parte de la operación se apoya en herramientas como Excel, lo cual incrementa el riesgo de pérdida de información y falta de control.

4.4 Checklist de Cumplimiento (Gobierno de Datos)

Tabla 3: Checklist general de cumplimiento normativo

N°	Categoría	Criterio	Nivel	Evidencia / Recomendación
1	Consentimiento	Se solicita autorización para el tratamiento de datos personales	**Parcial**	Implementar checkbox de consentimiento y política de privacidad
2	Datos personales	Se recolectan solo los datos necesarios	**Parcial**	Aplicar principio de minimización de datos
3	Seguridad	La información está protegida mediante cifrado	**No cumple**	Implementar HTTPS y cifrado en base de datos
4	Acceso	Existe control de acceso por roles	**Parcial**	Implementar RBAC con roles claramente definidos
5	Auditoría	Se registran logs de actividad del sistema	**No cumple**	Implementar sistema de logs y monitoreo
6	Retención	Se define política de retención de datos	**No cumple**	Definir política de retención y eliminación
7	Integraciones	Las APIs externas son seguras	**Parcial**	Usar autenticación segura, validación de webhooks y manejo seguro de API keys
8	Disponibilidad	El sistema tiene mecanismos de alta disponibilidad	**Parcial**	Implementar backups, balanceadores y redundancia
9	Derechos del usuario	El usuario puede acceder, modificar o eliminar sus datos	**No cumple**	Implementar módulo de gestión de datos del usuario
10	Cumplimiento legal	Se cumple con la Ley 1581 de protección de datos	**Parcial**	Definir e implementar políticas formales de protección de datos

4.5 Resultados del Análisis de Cumplimiento

4.5.1 Cumplimientos Parciales

Se evidencian algunos avances iniciales en:

- Gestión básica de información de clientes y reservas.

- Diferenciación de tipos de usuarios (administrador, personal operativo).
- Intención de implementar una arquitectura tecnológica más robusta.

Sin embargo, estos aspectos no están completamente formalizados ni alineados con estándares normativos.

4.5.2 Brechas Identificadas

Se detectaron múltiples brechas relevantes en materia de cumplimiento:

- Falta de consentimiento informado para el tratamiento de datos personales.
- Ausencia de políticas de privacidad y tratamiento de datos.
- No implementación de cifrado en almacenamiento o transmisión de información.
- Falta de control de acceso basado en roles (RBAC).
- Ausencia de registros de auditoría (logs).
- No definición de políticas de retención de datos.
- Limitaciones en la gestión de derechos del usuario (Habeas Data).

Estas brechas representan riesgos significativos en términos de seguridad, cumplimiento legal y confianza del usuario.

4.6 Nivel de Madurez

El sistema presenta un **nivel de madurez bajo** en cumplimiento normativo, ya que la mayoría de los controles requeridos por la Ley 1581 y estándares como ISO 27001 no están implementados o se encuentran en estado inicial.

4.7 Riesgos Asociados

Las debilidades identificadas pueden generar los siguientes riesgos:

- Exposición de datos personales de clientes.
- Sanciones legales por incumplimiento normativo.
- Pérdida de confianza por parte de usuarios y clientes.
- Inconsistencias en la información de reservas.
- Vulnerabilidad ante ataques o accesos no autorizados.

4.8 Recomendaciones

4.8.1 Protección de Datos Personales

- Implementar mecanismos de consentimiento informado.
- Definir y publicar una política de tratamiento de datos personales.
- Permitir a los usuarios ejercer sus derechos de acceso, modificación y eliminación de datos.

4.8.2 Seguridad de la Información

- Implementar cifrado de datos en tránsito (HTTPS) y en almacenamiento.
- Establecer controles de acceso basados en roles (RBAC).
- Implementar logs y monitoreo de actividades.

4.8.3 Gestión Operativa

- Definir una política de retención y eliminación de datos.
- Implementar backups automáticos y mecanismos de recuperación.
- Reducir la dependencia de herramientas manuales como Excel.

4.8.4 Integraciones Externas

- Asegurar la integración con Airbnb mediante validación de webhooks, uso de claves API seguras y control de accesos.

4.9 Conclusión del Taller 6

El análisis realizado evidencia que el sistema actual presenta importantes oportunidades de mejora en materia de cumplimiento normativo y seguridad de la información. Si bien la solución aún se encuentra en una etapa inicial de madurez, la adopción de una arquitectura moderna y la implementación de controles alineados con la Ley 1581 de 2012 y la norma ISO 27001 permitirán fortalecer la protección de datos, mejorar la confiabilidad del sistema y garantizar su escalabilidad futura.

5. Parte IV — Integración de Hallazgos y Conclusiones Generales

5.1 Visión Integrada de los Tres Talleres

La lectura conjunta de los tres talleres permite identificar un patrón claro: las debilidades detectadas en los tres frentes (arquitectura, seguridad y cumplimiento) **no son problemas aislados, sino manifestaciones distintas de las mismas causas raíz**. La siguiente tabla sintetiza cómo cada hallazgo técnico del Taller 4 se traduce en una amenaza concreta (Taller 5) y en una brecha de cumplimiento (Taller 6).

Tabla 4: Integración de hallazgos entre los tres talleres

Tema	T4 (Infraestructura)	T5 (STRIDE)	T6 (Cumplimiento)
Autenticación y acceso	Authentication sin redundancia clara	Spoofing / Elevation of Privilege	Ausencia de RBAC formal
Datos de clientes	PostgreSQL sin cifrado explícito	Information Disclosure (Alto)	Criterio 3 y 9 no cumplidos
Trazabilidad	Monitoring solo en capa de datos	Repudiation sin logs	Criterio 5 (auditoría) no cumplido
Disponibilidad	SPOF en LB y WAF	Denial of Service (Alto)	Criterio 8 parcial
Integración Airbnb	Sin mecanismo de reintento robusto	Tampering / Info. Disclosure	Criterio 7 parcial

5.2 Plan de Acción Priorizado

A partir de la integración de los tres análisis, se propone el siguiente orden de prioridad para las acciones correctivas, considerando tanto el impacto como la facilidad relativa de implementación:

1. **Corto plazo (crítico)**: Implementar HTTPS, cifrado de datos sensibles, MFA para cuentas administrativas y sistema de logs con timestamps. Estos controles atacan simultáneamente los tres frentes analizados.

2. **Corto plazo (alto)**: Definir y publicar política de tratamiento de datos personales, implementar consentimiento informado y mecanismos de ejercicio de derechos del usuario. Cierra las brechas más visibles frente a la Ley 1581.

3. **Mediano plazo**: Implementar RBAC formal, extender el monitoreo a todas las capas, configurar Multi-AZ para Load Balancer y WAF, y establecer mecanismos de reintento con *backoff* para webhooks de Airbnb.

4. **Mediano-largo plazo**: Migrar el Compute Layer a AWS Auto Scaling Groups o EKS, adoptar mTLS entre microservicios (Zero Trust) y reducir progresivamente la dependencia operativa de herramientas manuales (Excel).

5.3 Reflexión del Equipo sobre el Trabajo del Semestre

El desarrollo de los tres talleres permitió al equipo **Cyber Nexus — Grupo 7** recorrer de manera práctica el ciclo completo de evaluación de un sistema empresarial: desde la comprensión de su arquitectura hasta la verificación de su cumplimiento normativo, pasando por el análisis estructurado de amenazas. Este recorrido dejó varios aprendizajes clave para el equipo:

- **La arquitectura no es un tema puramente técnico**: toda decisión de diseño tiene implicaciones de seguridad y de cumplimiento que solo se hacen visibles cuando se miran las tres dimensiones simultáneamente.
- **Los marcos de referencia (STRIDE, OWASP, NIST, ISO 27001, Ley 1581) no son listas burocráticas**: son herramientas prácticas que ayudan a estructurar el análisis y a no dejar fuera aspectos críticos.
- **La mayoría de las mejoras recomendadas son implementables con tecnologías estándar**: el principal obstáculo no es técnico sino organizacional (falta de políticas formales, ausencia de procesos documentados, dependencia de herramientas manuales).
- **El trabajo en equipo con división de responsabilidades** fue determinante para cubrir los tres ejes con el nivel de detalle requerido en cada entrega.

5.4 Conclusión General

El trabajo realizado a lo largo del semestre sobre la plataforma de gestión de propiedades y reservas ha demostrado que, aunque el sistema cuenta con una base arquitectónica moderna desplegada en AWS, presenta **brechas significativas en las tres dimensiones analizadas**: alta disponibilidad y observabilidad en la infraestructura, controles técnicos de ciberseguridad y cumplimiento normativo frente a la Ley 1581 e ISO 27001.

Estas brechas no son triviales, pero tampoco son insalvables: la gran mayoría se cierra con controles estándar (MFA, HTTPS, cifrado, RBAC, logs, Multi-AZ) que, aplicados de forma coordinada, permitirían al sistema pasar de un nivel de madurez bajo a un nivel aceptable para operar en producción con datos personales de clientes.

Para el equipo, este proyecto integrador ha sido una oportunidad valiosa para aplicar de forma articulada los conceptos de arquitectura empresarial, ciberseguridad y gobierno de datos sobre un mismo caso de estudio. Consideramos que el ejercicio cumple con los objetivos del curso y, más allá de la calificación, nos deja un marco de análisis replicable para futuros proyectos profesionales.

6. Referencias Consolidadas

6.1 Arquitectura de Infraestructura (Taller 4)

- Amazon Web Services. (2023). *AWS Well-Architected Framework*. https://aws.amazon.com/architecture/well-architected/
- Microsoft Azure. (2023). *Cloud Architecture Best Practices*. https://learn.microsoft.com/en-us/azure/architecture/
- Google Cloud. (2023). *Infrastructure Architecture Framework*. https://cloud.google.com/architecture

6.2 Ciberseguridad (Taller 5)

- OWASP Foundation. *OWASP Top Ten*. https://owasp.org/www-project-top-ten/
- OWASP Foundation. *OWASP API Security Project*. https://owasp.org/www-project-api-security/
- NIST. *Cybersecurity Framework*. https://www.nist.gov/cyberframework
- Amazon Web Services. *AWS Cloud Security*. https://aws.amazon.com/security/
- Cloudflare. *What is a DDoS Attack?* https://www.cloudflare.com/learning/ddos/what-is-a-ddos-atta

6.3 Cumplimiento Normativo (Taller 6)

- Congreso de Colombia. (2012). *Ley 1581 de 2012 — Protección de Datos Personales*.
- ISO/IEC 27001. *Information Security Management Systems*.
- Ministerio de Tecnologías de la Información y las Comunicaciones (MinTIC). *Lineamientos de buenas prácticas en transformación digital y seguridad*.
- Habeas Data (Colombia) — Derecho constitucional al acceso, rectificación y eliminación de información personal.

Fin del informe consolidado

Cyber Nexus — Grupo 7

Arquitectura Empresarial — Universidad de La Sabana